

## ***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

Un protocole est un ensemble de règles à respecter au cours d'une communication sur un réseau informatique. Les protocoles diffèrent les uns des autres par l'objectif de la communication.

Un protocole de sécurité est un protocole qui utilise des primitives cryptographiques ou des mécanismes de sécurité afin d'assurer certains objectifs de sécurité comme l'authentification, la confidentialité, la non-répudiation et l'intégrité dans des communications contenant de l'information sensible.

### **2.1 Éléments du protocole**

- Principal: Un principal est un agent qui participe au moins dans une session d'exécution du protocole. Il est noté par une lettre majuscule  $A, B, S$ , etc.
- Nonce, Timestamp: Une nonce, est un message aléatoire généré par un agent et échangé avec un autre agent. Elle est utilisée principalement pour des besoins de fraîcheur. On la note par  $Na, Nb$ , etc. Un timestamp permet aussi d'assurer la fraîcheur d'un message et contient un aspect temps. On le note par  $Ta, Tb$ , etc.
- Message: Les agents dans un protocole cryptographique échangent des messages qui peuvent être :
  - une identité d'un principal :  $IDa, IDb$
  - une identité d'un serveur :  $IDs$  ;
  - des nonces :  $Na, Nb$
  - des clés d'encryption/décryption :  $Kab$ ,
  - un message  $m$  encrypté avec une clé  $k$  :  $\{m\}_k$  ;
  - un message composé :  $M1.M2, ,,,,,,$  etc.

### **2.2 Étape de communication**

Une étape de communication d'un protocole identifie une phase d'envoi de message entre deux agents. Elle est notée par  $i$  : Principal  $\rightarrow$  Principal :  $m$  telle que  $i \in [1,n]$

#### **Exemple**

1 :  $A \rightarrow B$  : Bonjour, es-tu là ?

## ***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

2 :  $B \rightarrow A$  : Bonjour , oui, je suis là

**Exemple** (avec fraîcheur en utilisant une nonce)

1 :  $A \rightarrow B$  : es-tu là ?,  $Na$

2 :  $B \rightarrow A$  : "oui, je suis là",  $Na, Nb$

**Exemple** (avec fraîcheur en utilisant un timestamp)

1 :  $A \rightarrow B$  : es-tu là ?

2 :  $B \rightarrow A$  : oui, je suis là",  $Tb$

### **2.3 Classification des protocoles**

Les protocoles cryptographiques peuvent être classés subjectivement selon plusieurs critères :

- Par système cryptographique : un protocole peut se baser sur une cryptographie symétrique, une cryptographie asymétrique ou une cryptographie symétrique et asymétrique à la fois ;
- Par objectif du protocole : il peut être également classifié selon son le but qu'il doit assurer : authentification, distribution et gestion de clés, etc. ;
- Par nombre de messages : il peut être classifié selon le nombre d'étapes de communication qu'il utilise pour assurer la propriété de sécurité pour laquelle il est conçu : un message, deux messages, etc;

### **2.4 Trace d'exécution**

Une trace d'exécution est un déroulement du protocole où tous les agents honnêtes qui y participent respectent la spécification du protocole.

## ***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

### **2.5 Intrus**

Un intrus est un attaquant qui s'infiltré dans un protocole, d'une façon illicite, et qui cherche à exploiter les failles éventuelles de ce protocole. Il est supposé se doter de moyens très importants et d'une expertise redoutable dans la composition des messages et leur manipulation. Il peut être un agent régulier possédant ses propres clés comme il peut être une entité étrangère.

### **2.6 Distribution et la gestion des clés secrètes**

L'objectif des protocoles de gestion de clés consiste à distribuer des clés à des principaux légaux du système informatique pour assurer la confidentialité et l'intégrité de l'information qui sera transmise entre ces principaux dans leurs communications ultérieures. En d'autres mots, ces protocoles distribuent une ou plusieurs clés à des principaux qui en ont fait la demande. Ils pourront, par la suite, utiliser celles-ci pour encoder et décoder l'information qu'ils s'échangeront dans les prochaines heures, ou jours, tout dépendant de la longévité de la clé qu'ils viennent d'obtenir.

#### **2.6.1. Distribution des clés secrètes dans système symétrique 2.6.1.1.**

##### **Gestion des clé : Needham-Schroeder – version symétrique**

Le protocole Needham-Schroeder (version symétrique) est l'un des deux protocoles de distribution des clés destinés à être utilisés sur un réseau non sécurisé, il tient son nom des créateurs Roger Needham et Michael Schroeder. Needham et Schroeder proposent des protocoles de distribution des clés pour les systèmes symétrique (voir figure 2.1)

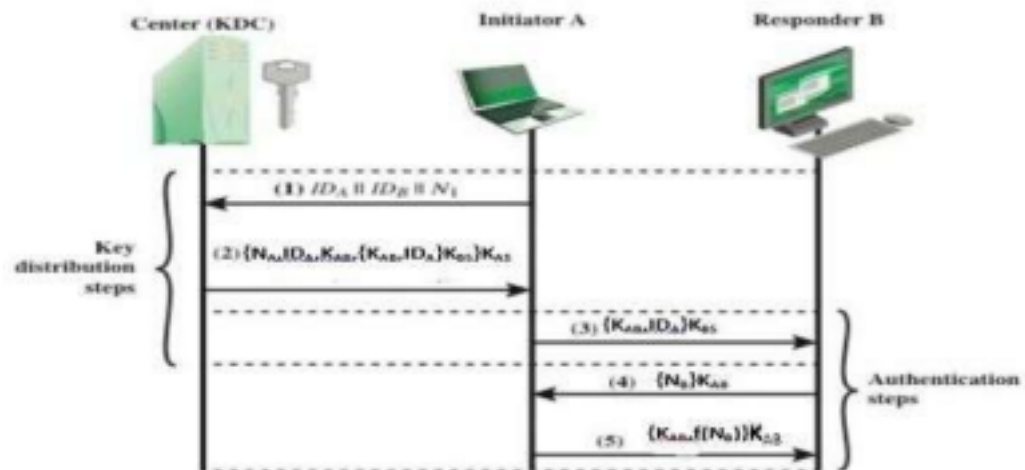
Pour le protocole symétrique Needham et Schroeder supposent que chaque utilisateur Alice et bob a une clé privée (secrète)  $K_{as}$  et  $K_{bs}$  respectivement qui sont connus seulement pour eux et le serveur. Si Alice et Bob souhaitent une communication

sécurisée, Alice doit obtenir une clé de communication secrète  $K_{ab}$  du serveur et en

Page 9

## Chapitre II : Distribution des clés secrètes et des clés publiques, certificats

remettre une copie au Bob. Le protocole de distribution des clés est le suivant, il comporte exactement 5 étapes :



**Figure 2. 1 Le protocole Needham-Schroeder (version symétrique)**

□ Étape 01 :  $A \rightarrow S : A, B, N_A$

Alice envoie un message au serveur pour s'identifier et identifier bob, le message contient l'id d'alice, l'id de bob et le nonce d'alice (random number  $N_a$ ), en ce moment les clés secrètes sont partagées entre bob et le serveur ( $K_{bs}$ ) et entre alice et le serveur ( $K_{as}$ ).

□ Étape 02 :  $S \rightarrow A : \{N_a, B, K_{ab}, \{K_{ab}, A\} K_{bs}\} K_{as}$

Le serveur génère une clé de session ( $K_{ab}$ ) et envoie une copie cryptée de cette clé à Alice aux côtés de son nonce et l'identité de Bob pour assurer que le message est rejouer à ce message particulier , une copie est cryptée avec la clé secrète d'Alice ( $K_{as}$ ) tandis que l'autre est crypté en utilisant la clé secrète de Bob ( $K_{bs}$ ) .

□ Étape 03 :  $A \rightarrow B : \{K_{ab}, A\} K_{bs}$

Alice envoie la clé de session chiffrée ( $K_{ab}$ ) à Bob pour qu'il puisse la déchiffrer à l'aide de sa propre clé secrète ( $K_{bs}$ ).

Après l'étape 03 , Alice peut être sûre que la clé  $K_{ab}$  est sûre à utiliser. Cependant, Bob ne peut pas être sûr que les messages cryptés par  $K_{ab}$  qui ont été envoyés par

Alice ne sont pas des replays de messages précédents. Pour protéger contre ces replays, une handshake entre Bob et Alice suit :

Page 10

## ***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

□ Etape 04 :  $B \rightarrow A: \{Nb\}_{Kab}$

Bob récupère la clé de session ( $K_{ab}$ ) et envoie un nonce ( $Nb$ ) chiffré en utilisant ( $K_{ab}$ ).

□ Etape 05:  $A \rightarrow B : \{Nb-1\}_{Kab}$

Alice signale son intention d'utiliser  $K_{ab}$  en retournant une fonction convenue  $f$ .

### **2.6.1.2. Kerberos**

Kerberos développe par le MIT (Massachusetts Institute of Technology), Kerberos est un système d'authentification sécurisé à tierce personne de confiance (ou TA pour Trusted Authority) conçu pour les réseaux TCP/IP.

Kerberos est un service basé sur la cryptographie symétrique pour assurer l'authentification dans les réseaux ouverts.

Kerberos partage avec chaque entité  $U$  du réseau une clé secrète  $K_U$  et la connaissance de cette clé tient lieu de preuve d'identité.

L'authentification est négociée par le biais d'un tiers de confiance : le Key Distribution Center (KDC). Des extensions existent pour l'utilisation de certificats qui permettent un meilleur passage à l'échelle.

Kerberos possède un certain nombre d'avantages :

- c'est un standard IETF (RFC 1510) supporté par de nombreux OS (en particulier Windows 2000)
- l'authentification est sécurisée ;
- il n'y a pas de transmission de mot de passe sur le réseau ;
- le Single Sign On : il suffit que l'utilisateur s'authentifie une seule fois lors de la première authentification. Il n'a ainsi qu'un seul mot de passe à se souvenir et ne l'entre qu'une seule fois par jour typiquement ;
- une gestion centralisée de l'authentification ;

L'utilisation de Kerberos fait appel à un vocabulaire dont les principaux termes sont énumérés ici :

Page 11

## ***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

□ KDC (Key Distribution Center) : Base de Données des clients et des serveurs (les 'principaux') ainsi que des clés privées associées. Le *Key Distribution Center (KDC)* est la composante principale de l'architecture.

Cette composante offre les deux principaux services:

*Authentication Service (AS)* : Service authentifiant un *principal*. *Ticket*

*granting service (TGS)* : Service offrant à un *principal* un ticket permettant d'être authentifié par un autre *principal*. Ce ticket peut contenir aussi les droits d'accès du *principal*.

□ Client : Entité pouvant obtenir un ticket

□ Service : Programme/ordinateur accède sur un réseau.

□ Ticket : Crédit temporaire permettant de vérifier l'identité du détenteur. □

TGT : Ticket particulier permettant au détenteur d'obtenir d'autres tickets pour le même domaine.

Les étapes de l'authentification dans le protocole Kerberos sont présentées la figure 2.2 Avant de détailler plus particulièrement ces étapes, il convient de donner les grandes lignes du protocole Kerberos. Kerberos est basé sur l'utilisation de tickets qui serviront à convaincre une entité de l'identité d'une autre entité. Il crée également des clés de session qui sont données à deux participants et qui servent à chiffrer les données entre ces deux participants.

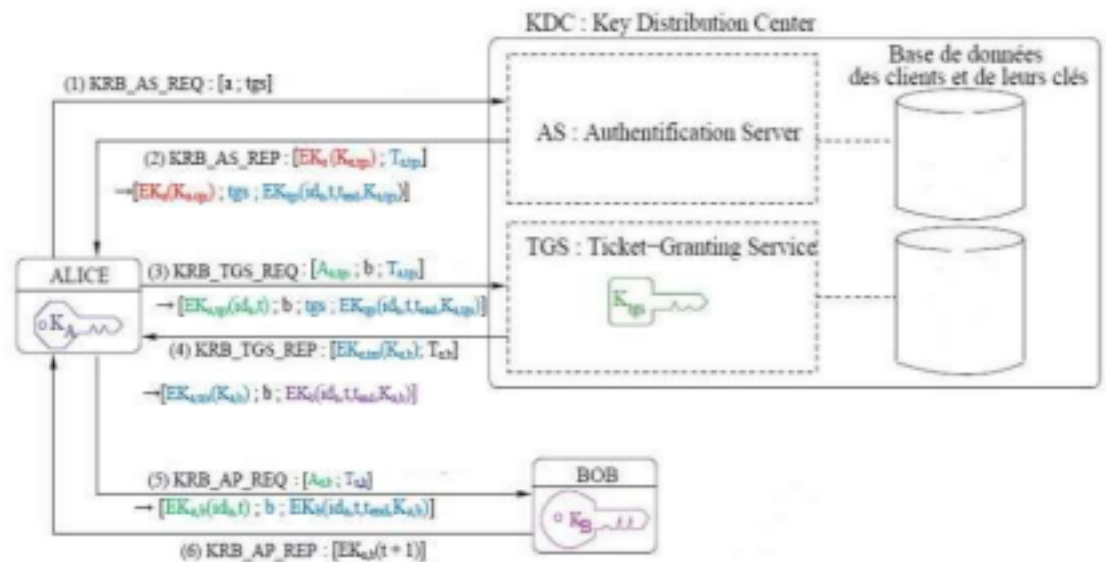


Figure 2. 2 Le protocole Kerberos

## Chapitre II : Distribution des clés secrètes et des clés publiques, certificats

- KRB AS REQ : Ce message sert simplement d'introduction à Alice. Elle y précise son nom et quel TGS elle souhaite rencontrer.
- KRB AS REP : Le serveur d'authentification cherche le client dans sa base de données. S'il le trouve, il engendre une clé de session  $K_{a,tgs}$  qui devra être utilisée entre Alice et le TGS. Cette clé est d'une part chiffrée avec la clé secrète  $K_a$  d'Alice : c'est la première partie du message ( $EK_a(K_{a,tgs})$ ). Ensuite, il crée un ticket  $T_{a,tgs}$  pour Alice afin que celle-ci puisse s'authentifier auprès du TGS. Ce ticket est chiffré avec la clé secrète  $K_{tgs}$  du TGS. Alice ne pourra pas le déchiffrer mais pourra le présenter tel quel à chaque requête au TGS. Dans ce cas particulier, le ticket est appelé TGT. Il est important de noter que seule la véritable Alice est capable de récupérer la clé de session  $K_{a,tgs}$  (elle est la seule à posséder la clé secrète  $K_a$ ). Ainsi, Alice dispose maintenant de la clé de session  $K_{a,tgs}$  et du TGT  $T_{a,tgs}$ .
- KRB TGS REQ : Alice doit maintenant obtenir un nouveau ticket pour chaque Bob qu'elle souhaite contacter. Pour cela, Alice contacte le TGS en lui fournissant d'une part le ticket TGT  $T_{a,tgs}$  qu'elle possède déjà, et un authentifiant  $A_{a,tgs}$  d'autre part (en plus du nom du serveur qu'elle souhaite contacter). L'authentifiant possède des informations formatées vérifiables à

partir du ticket par le TGS et comme ces informations sont chiffrées avec la clé de session  $K_{a,tgs}$  cela prouve au moins qu'Alice la connaît et donc l'authentifie (d'où le nom d'authentifiant donné à  $A_{a,tgs}$ ).

- KRB TGS REP : Grâce à sa clé secrète  $K_{tgs}$  le TGS déchiffre le ticket, récupère la clé de session  $K_{a,tgs}$  et peut ainsi déchiffrer l'authentifiant  $A_{a,tgs}$ . Il compare le contenu de l'authentifiant avec les informations contenues dans le ticket et si tout concorde (Alice est authentifiée), il peut engendrer une clé de session  $K_{a,b}$  (qui sera utilisée entre Alice et Bob) qu'il chiffre avec la clé de session  $K_{a,tgs}$  et un nouveau ticket  $T_{a,b}$  qu'Alice devra présenter à Bob. Après la réception de ce message et déchiffrement, Alice dispose donc en plus de  $K_{a,tgs}$  et de  $T_{a,tgs}$  (qu'elle conserve jusqu'à expiration du ticket pour dialoguer avec TGS) d'une nouvelle clé de session  $K_{a,b}$  et d'un nouveau ticket  $T_{a,b}$  qu'elle pourra utiliser avec Bob.

### Page 13

## ***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

- KRB AP REQ : Maintenant, Alice est prête à s'authentifier auprès de Bob ; cela s'effectue de la même manière qu'entre Alice et le TGS.
- KRB AP REP : Il reste maintenant à Bob à s'authentifier en prouvant qu'il a pu déchiffrer le ticket  $T_{a,b}$  et donc qu'il possède la clé de session  $K_{a,b}$ . Il faut donc qu'il renvoie une information vérifiable par Alice chiffrée avec cette clé. Pour éviter les attaques de type replay, l'information choisie est  $t+1$ . En vérifiant cela, Alice est maintenant sûre de l'identité de Bob et dispose d'une clé de session  $K_{a,b}$  utilisable pour chiffrer les communications entre Alice et Bob.

### **2.6.2. Distribution des clés secrètes dans système asymétrique**

Le chiffrement asymétrique utilise deux clés principales dont la clé publique qui peut être partagée à de nombreux usagers et la clé privée qui sera gardée confidentielle. La figure ci-dessous décrit le processus de la signature ainsi que le chiffrement et le déchiffrement d'un message

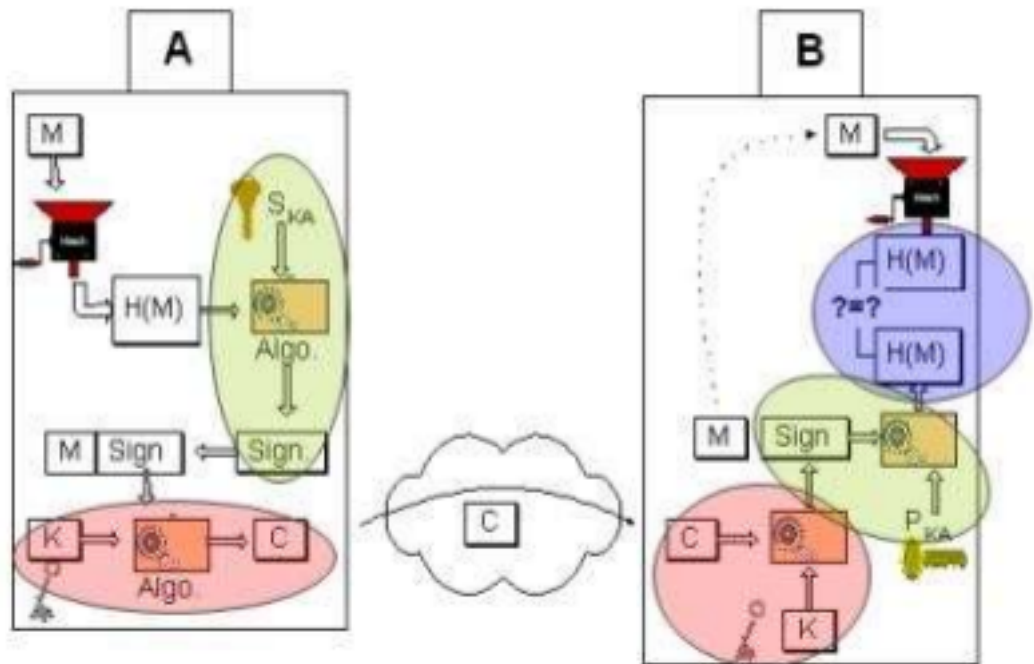


Figure 2. 3 Authentification, confidentialité, intégrité dans système asymétrique

Page 14

## ***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

Pour assurer l'authenticité des messages le principal A peut encrypter (dans ce cas on dit signer) les messages avec sa clé privé. Ainsi, tous les autres principaux peuvent décrypter ces messages en utilisant la clé publique de A. Afin d'assurer la confidentialité le participant A encrypte les messages avec la clé public avec la clé publique de B.

- Qui va nous garantir que la clé publique de B appartient bien à B, non pas à quel qu'autre.
- Est- on sur qu'il ne s'agit pas d'un vol identité

### **Scénario d'attaque :**



Figure 2. 4 Scénario d'attaque dans les systèmes asymétrique

Donc, les signatures ne résolvent pas entièrement le problème de l'authenticité. Il faut un moyen de prouver la correspondance entre une clé publique et une personne !

**La solution** : les certificats (Une certificat garantit que cette clé publique appartient bien à la personne que je souhaite communiquer).

## ***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

### **2.6.2.1 Les certificats**

Un certificat à clé publique est un certificat numérique qui lie l'identité d'un système à une clé publique, et éventuellement à d'autres informations ;

Un certificat est signé numériquement par une autorité de certification à qui font confiance tous les usagers et dont la clé publique est connue par tous d'une manière sécurisée. Un certificat est

- Délivré et certifié par une autorité de certification
- Nominatif

- À une durée de validité
- Révocable
- A usage unique

**Exemple : Structure d'un certificat X.509**

- Version
- Numéro de série
- Algorithme de signature du certificat
- Signataire du certificat
- Validité (dates limite)
- Détenteur du certificat
- Informations sur la clé publique (algorithme de la clé publique, clé publique)
- Id unique du signataire(Facultatif)
- Id unique du détenteur du certificat (facultatif)
- Extension (facultatif)
- Signature

**Création d'un certificat**

Alice génère ses clés PK (clé public) et SK( clé privé), Elle émet une requête au CA pour un certificat de PK. CA valide la clé, authentifie Alice et génère un certificat, le certificat est signé par le CA. Cette signature certifie l'origine du certificat et son

Page 16

***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

intégrité. Le certificat est publié dans un annuaire public. La figure suivante présente le processus de création d'un certificat.

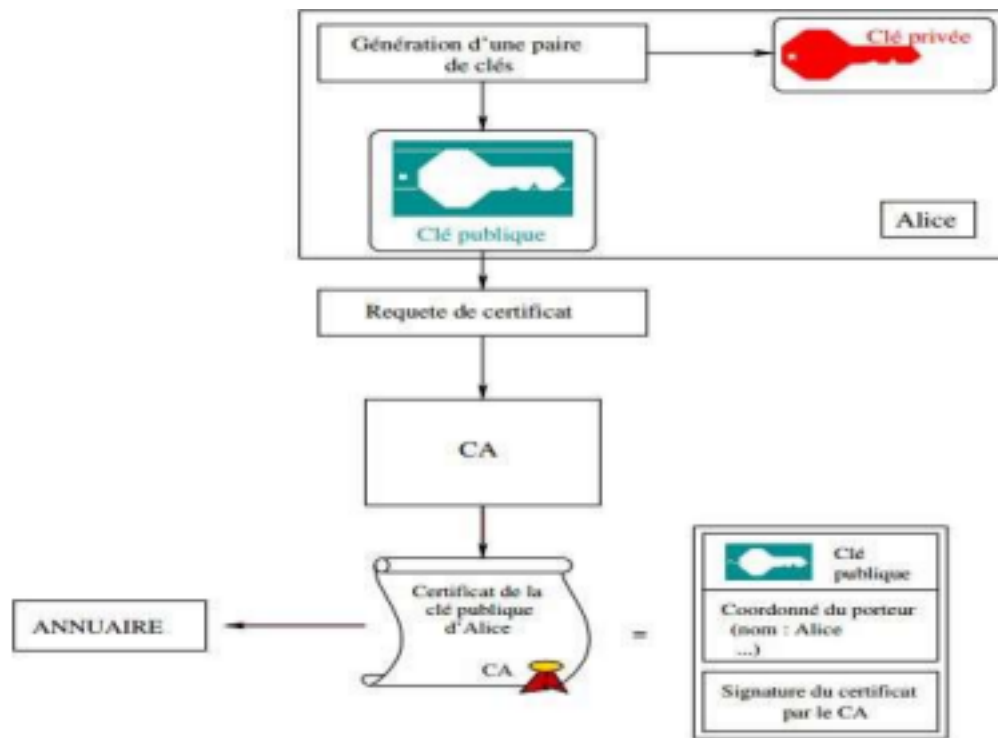


Figure 2. 5 processus de création de certificat

>>>>>> Qui va signer, qui va diffuser les certificats et dans quel annuaire. Cela nécessite une infrastructure

**Solution** : PKI

### 2.6.2.2 Infrastructure à clé publique (PKI)

Ensemble de composants, fonctions et procédures dédiés à la gestion de clés et de certificats utilisés par des services de sécurité basés sur la cryptographie à clé publique. PKI est utilisé pour :

- Enregistrement des utilisateurs
- Vérifications des attributs
- Génération des certificats
- Publication des certificats valides et révoqués
- Identifications et authentification des utilisateurs

## ***Chapitre II : Distribution des clés secrètes et des clés publiques, certificats***

- Archivages des certificats

### ❖ Les acteurs du certificat

### ✓ Le porteur

entité qui possède une clé privée.

le certificat numérique contient la clé publique associée.

Plusieurs type de certificat : client, serveur ,,ect

### ✓ Utilisateur d'un certificat

□ récupère le certificat

✓ il utilise le certificat :

✓ vérifie que le certificat n'est pas révoquer

✓ vérifie que l'identité indiqué par le certificat est bien son interlocuteur

✓ Authentifie et Vérifie l'intégrité du certificat à l'aide de la clé publique de CA

### ✓ L' Autorité de Certification (AC)

Ensemble de ressources défini par son nom et sa clé publique qui :

génère et émet les certificats ;

diffuse la valeur de sa clé publique

publie les certificats non encore expires ;

À la confiance des utilisateurs ;

maintient les archives des certificats expires/révoqués.

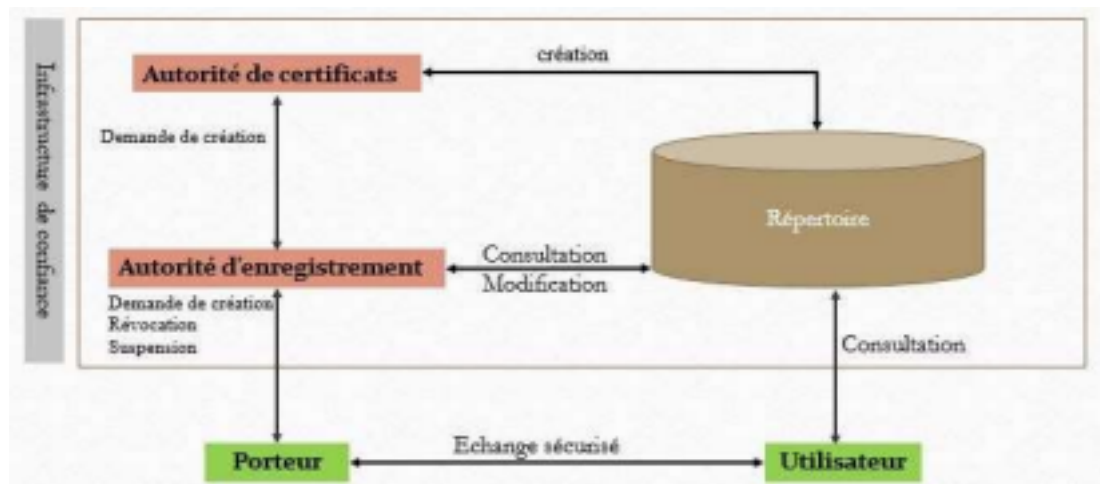


Figure 2. 6 Les acteurs du certificat

Le modèle de confiance hiérarchique est une structure arborescente inversée, à la racine se situe l'autorité de confiance suprême à qui tout le monde fait confiance, la RootCA. La RootCA certifie toutes les autorités de niveau inférieur dans la hiérarchie de l'arbre, elle émet le certificat des autorités subordonnées (subCA) et si nécessaire ceux des utilisateurs. Ensuite au niveau inférieur, c'est-à-dire au niveau des branches, on peut y trouver des autorités de certification subordonnées (subCA). Il peut y avoir sous certaines conditions plusieurs niveaux de certification subordonnée.

Les subCAs émettent les certificats utilisateur et ceux des subCAs de niveau inférieur. La présence des subCAs n'est pas obligatoire. Au niveau des feuilles se trouve l'utilisateur qui est le consommateur des services de certification. Toutes les entités du modèle doivent faire confiance à l'autorité de certification racine et conserver son certificat. En général, les utilisateurs conservent les certificats de toutes les CAs inclus dans le chemin de certification de leurs certificats. Le modèle hiérarchique est schématisé dans la figure suivant.

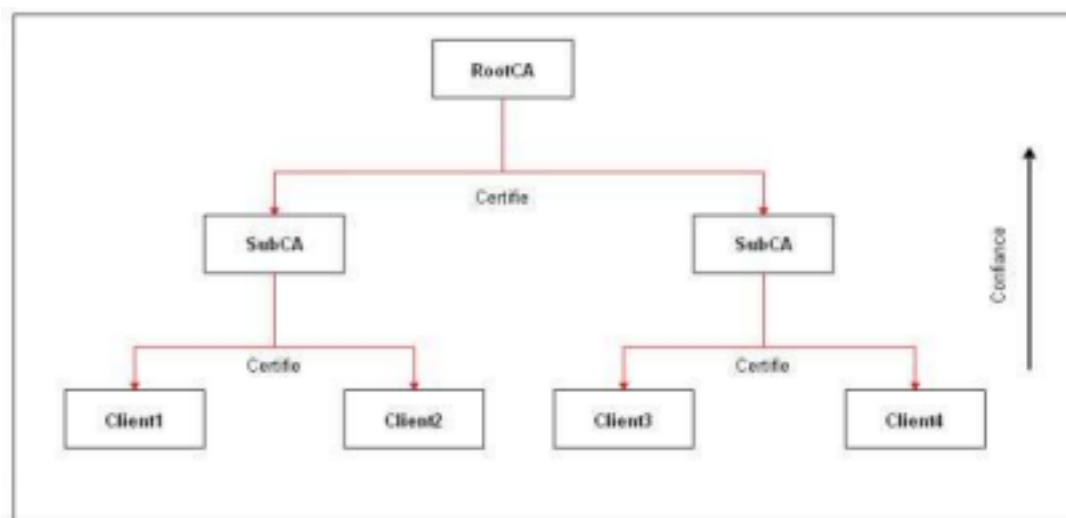


Figure 2. 7 Modèle de confiance hiérarchique